

AUDIT DOSSIER: Threshold Network tBTC Bridge v2
Technical Integrity Report
Date: 2026-06-01
Auditor: RamÃ³n Rivas (@jramonrivasg)

1. Executive Summary

This report outlines two critical vulnerabilities identified in the 'RebateStaking.sol' contract of the Threshold Network tBTC Bridge v2, which directly threaten the integrity of the staking and rebate mechanisms.

2. Vulnerability Details

I. Arithmetic Underflow (Panic 0x11):

The 'applyForRebate' function fails to handle consecutive rebate applications within the same block timestamp. The logic fails to maintain state consistency, leading to an arithmetic underflow that triggers a 'Panic(0x11)' error, resulting in a complete Denial of Service for the affected user.

II. State Corruption via 'forceStakeTransfer':

The 'forceStakeTransfer' function performs an insecure migration of the 'rollingWindowStartIndex'. By resetting the index of the 'oldStake' to '0' without validating the existing rebate window, the contract corrupts the historical state, leading to inconsistent tracking and persistent failure of subsequent 'applyForRebate' operations.

3. Risk and Impact

Combined, these vulnerabilities allow for a permanent Denial of Service over stakeholders' funds. The state corruption enables the effective invalidation of accumulated rebate rights, while the arithmetic underflow prevents access to the rebate functionality entirely under normal high-activity conditions.

4. Methodology

To identify and confirm these findings, the following strategies were employed:

- * **Timestamp Collision Analysis:** Identification of logic failures by stressing the rebate application sequence within identical block timestamps.
- * **State Transition Stress Testing:** Isolation of the 'forceStakeTransfer' function to observe index management inconsistencies during stake migration.
- * **Invariant Verification:** Implementation of Foundry-based Proof of Concept (PoC) tests to systematically reproduce the 'Panic(0x11)' failure and confirm the state corruption, ensuring the audit results are verifiable and reproducible against the target bytecode.

5. Proof of Concept (PoC) Access

The PoC is hosted in a private repository to ensure security during the disclosure process:

- * **Link:** [https://github.com/Jramone3/threshold-staking-bunker-poc] (https://github.com/Jramone3/threshold-staking-bunker-poc)
- * **Verification Instructions:**
 1. 'forge install'
 2. 'forge build'
 3. 'forge test --match-path test/FinalValidation.t.sol -vvvv --fork-url <YOUR_RPC_URL>'

Note on Access: For security reasons, the repository is currently private. Please notify me upon receipt of this report so I can grant you the necessary authorization to review the PoC and source code.

6. Integrity Verification (Blockchain Notarized)

Hash of Patrimonial Index: '23c9c380ffbaeb23fceca5f31c771aca0395820e3986a208127cbf27a55927b9'
Blockchain Tx: 'a0a27afb6713c418eb886c6222dafff2122175fe61dde7ece6ba4c8d9a59b28e'